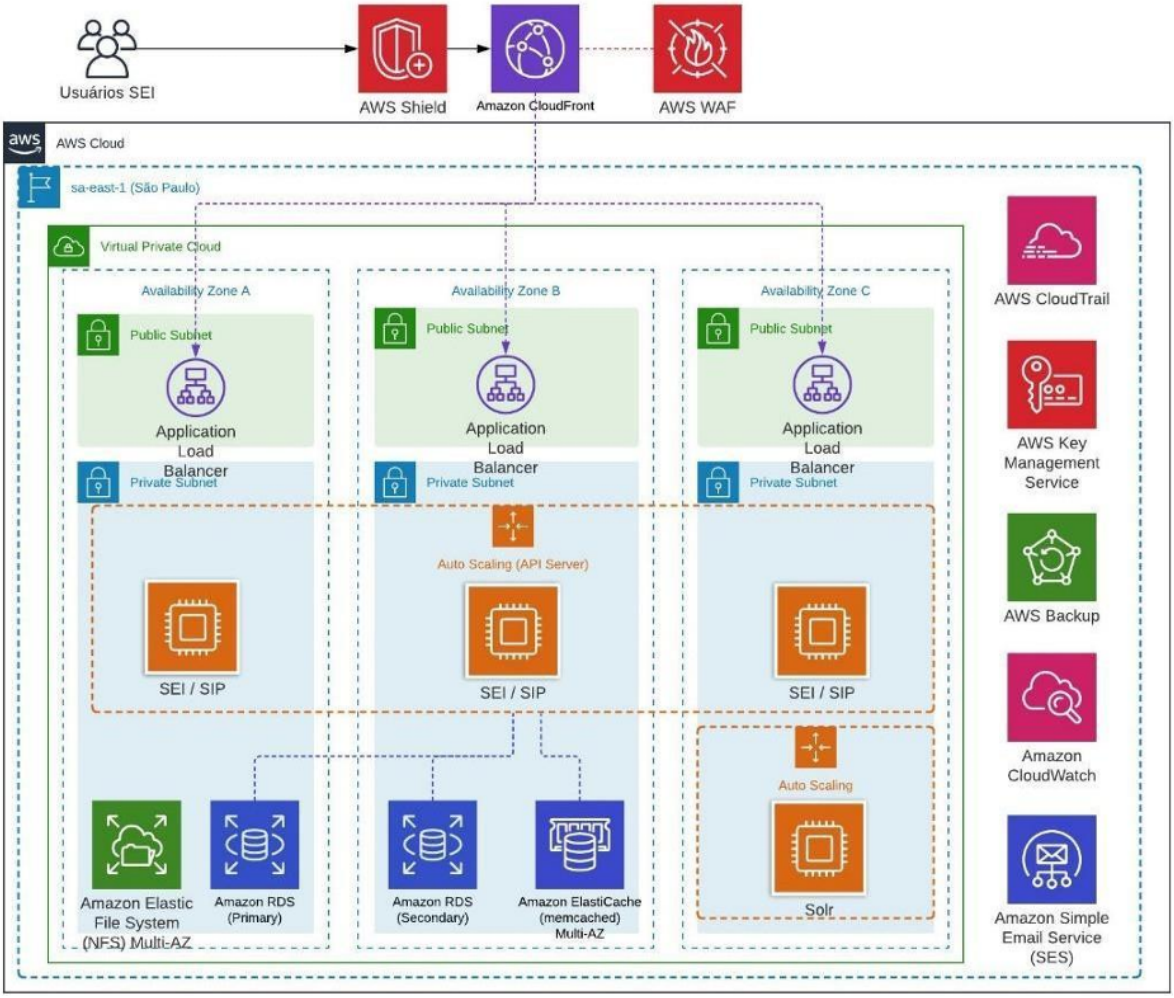
Relatório de Avaliação de Ameaças STRIDE

Data: 17/12/2024 às 14:35 **Classificação:** Uso Interno



Sumário Executivo

Foram analisados 21 componentes de uma arquitetura AWS distribuída, identificando 68 ameaças distintas. A análise revelou 8 ameaças críticas, 18 altas, 24 médias e 18 baixas. Os principais riscos concentram-se na exposição de dados através do CloudFront, configurações inadequadas do WAF/Shield, e possível comprometimento dos bancos RDS. Recomenda-se implementação imediata de criptografia em trânsito/repouso, hardening do WAF, e revisão de políticas IAM para mitigar os riscos críticos identificados.

---

1. Arquitetura Analisada

A aplicação é composta pelos seguintes componentes:

#	Componente	Tipo	Função na Arquitetura
1	CloudFront	CDN	Distribuição de conteúdo e cache global
2	Application Load Balancer (3x)	Load Balancer	Distribuição de tráfego entre instâncias
3	Compute (4x)	Instâncias/ Containers	Processamento da aplicação
4	ElastiCache	Cache	Cache de dados em memória
5	Simple Email Service	Mensageria	Envio de emails transacionais
6	Elastic File System	Storage	Sistema de arquivos compartilhado
7	AWS Backup	Backup	Backup automatizado de recursos
8	AWS Shield	Proteção DDoS	Proteção contra ataques DDoS
9	AWS WAF	Firewall Web	Filtro de requisições HTTP/HTTPS

#	Componente	Tipo	Função na Arquitetura
10	Key Management Service	Criptografia	Gerenciamento de chaves criptográficas
11	Amazon RDS (2x)	Banco de Dados	Armazenamento persistente de dados
12	CloudTrail	Auditoria	Log de atividades da API AWS
13	CloudWatch	Monitoramento	Métricas e logs da aplicação
14	Cloud9	IDE	Ambiente de desenvolvimento
15	Application Auto Scaling	Auto Scaling	Escalonamento automático de recursos

---

2. Análise de Ameaças STRIDE

Legenda STRIDE

- **S** - Spoofing (Falsificação de Identidade)
- **T** - Tampering (Adulteração de Dados)
- **R** - Repudiation (Repúdio)
- **I** - Information Disclosure (Vazamento de Informação)
- **D** - Denial of Service (Negação de Serviço)
- **E** - Elevation of Privilege (Elevação de Privilégio)

Matriz de Ameaças

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T001	CloudFront	I	Exposição de conteúdo sensível através de URLs não protegidas	Vazamento de dados confidenciais	Implementar Origin Access Control e signed URLs	Crítica

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T002	CloudFront	T	Cache poisoning através de headers maliciosos	Distribuição de conteúdo malicioso	Configurar cache behaviors restritivos e validação de headers	Alta
T003	CloudFront	S	Falsificação de origem através de certificados comprometidos	Impersonação da aplicação	Implementar Certificate Transparency monitoring	Média
T004	Application Load Balancer	D	Esgotamento de conexões através de flood de requisições	Indisponibilidade do serviço	Configurar connection draining e rate limiting	Alta
T005	Application Load Balancer	T	Manipulação de headers X-Forwarded através de proxy chains	Bypass de controles de segurança	Implementar validação rigorosa de headers trusted	Alta
T006	Application Load Balancer	E	Exploração de regras de roteamento mal configuradas	Acesso a recursos não autorizados	Implementar least privilege nas regras de target group	Média
T007	Compute Instances	E	Exploração de metadados IMDSv1 para obter credenciais	Comprometimento de credenciais AWS	Forçar uso de IMDSv2 e session tokens	Crítica
T008	Compute Instances	T	Adulteração de código em runtime através de memory corruption	Execução de código arbitrário	Implementar ASLR, stack canaries e container scanning	Alta

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T009	Compute Instances	S	Spoofing de identidade através de certificados de instância	Impersonação entre serviços	Implementar mTLS com rotação automática de certificados	Média
T010	Compute Instances	I	Exfiltração de dados através de side-channel attacks	Vazamento de dados sensíveis	Implementar isolamento de tenant e encrypted memory	Baixa
T011	ElastiCache	I	Exposição de dados sensíveis em cache não criptografado	Vazamento de informações críticas	Habilitar encryption at rest e in-transit	Crítica
T012	ElastiCache	T	Manipulação de chaves de cache através de injection	Corrupção de dados em cache	Implementar input sanitization e key validation	Alta
T013	ElastiCache	D	Redis/ Memcached flooding através de comandos pesados	Degradação de performance	Configurar maxmemory policies e command throttling	Média
T014	Simple Email Service	S	Spoofing de emails através de domínios não verificados	Phishing e impersonação	Implementar DKIM, SPF e DMARC policies	Alta
T015	Simple Email Service	I	Vazamento de dados pessoais através de bounces não tratados	Exposição de PII	Configurar bounce handling e data retention policies	Média

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T016	Simple Email Service	R	Negação de envio de emails críticos	Perda de auditoria de comunicação	Implementar logging detalhado e message tracking	Baixa
T017	Elastic File System	T	Corrupção de arquivos através de acesso concorrente	Perda de integridade dos dados	Implementar file locking e versioning	Média
T018	Elastic File System	E	Escalação através de permissões POSIX mal configuradas	Acesso não autorizado a arquivos sensíveis	Aplicar least privilege em file permissions	Alta
T019	Elastic File System	I	Exposição de dados através de snapshots não criptografados	Vazamento de dados históricos	Habilitar encryption at rest para EFS	Crítica
T020	AWS Backup	T	Adulteração de backups através de políticas inadequadas	Corrupção de dados de recuperação	Implementar backup immutability e cross-region replication	Crítica
T021	AWS Backup	R	Negação de restauração através de deletion policies	Perda permanente de dados	Configurar MFA delete e retention locks	Alta
T022	AWS Backup	E	Acesso a backups através de credenciais comprometidas	Exposição de dados sensíveis	Implementar cross-account backup e IAM boundaries	Média
T023	AWS Shield	D	Bypass de proteção DDoS		Upgrade para Shield	Alta

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
			através de novos vetores de ataque	Indisponibilidade prolongada do serviço	Advanced e custom mitigations	
T024	AWS Shield	I	Exposição de métricas de ataque sensíveis	Revelação de informações de infraestrutura	Restringir acesso às métricas do Shield	Baixa
T025	AWS WAF	D	Bypass de rules através de encoding/ obfuscation	Ataques web bem-sucedidos	Implementar rule testing e managed rule groups	Alta
T026	AWS WAF	T	Manipulação de rate limiting através de distributed requests	Bypass de proteções de abuse	Configurar geographic blocking e advanced rate limiting	Média
T027	AWS WAF	E	Escalação através de whitelisted IPs comprometidos	Bypass completo de proteções WAF	Implementar IP reputation monitoring	Média
T028	Key Management Service	E	Comprometimento de master keys através de políticas permissivas	Descriptografia não autorizada de dados	Implementar key policies restritivas e cross-account access	Crítica
T029	Key Management Service	R	Negação de acesso a chaves através de key deletion	Perda permanente de acesso a dados	Configurar key deletion waiting period e backup keys	Alta
T030	Key Management Service	I	Exposição de usage patterns através de CloudTrail	Revelação de padrões de criptografia	Implementar log filtering e data classification	Baixa

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T031	Amazon RDS	I	SQL injection resultando em data exfiltration	Vazamento massivo de dados	Implementar parameterized queries e WAF database rules	Crítica
T032	Amazon RDS	T	Modificação não autorizada através de privilege escalation	Corrupção de dados críticos	Aplicar least privilege e database activity monitoring	Alta
T033	Amazon RDS	D	Resource exhaustion através de connection flooding	Indisponibilidade do banco de dados	Configurar connection pooling e query timeout	Alta
T034	Amazon RDS	E	Exploração de stored procedures com privilégios elevados	Comprometimento completo do database	Remover stored procedures desnecessárias e review permissions	Média
T035	Amazon RDS	R	Negação de transações críticas através de rollback malicioso	Perda de integridade transacional	Implementar transaction logging e point-in-time recovery	Baixa
T036	CloudTrail	T	Manipulação de logs através de IAM permissions inadequadas	Perda de auditoria e compliance	Implementar log file integrity validation e cross-account logging	Crítica
T037	CloudTrail	R		Perda de rastro de auditoria	Configurar multi-region	Alta

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
			Negação de logging através de trail disabling		trails e service control policies	
T038	CloudTrail	I	Exposição de informações sensíveis através de event details	Vazamento de dados através de logs	Implementar data events filtering e log anonymization	Média
T039	CloudWatch	I	Exposição de dados sensíveis através de logs não filtrados	Vazamento de informações críticas	Configurar log filtering patterns e data masking	Alta
T040	CloudWatch	D	Metric flooding através de custom metrics abuse	Degradação do sistema de monitoramento	Implementar metric quotas e anomaly detection	Média
T041	CloudWatch	T	Manipulação de alertas através de threshold tampering	Supressão de alertas críticos	Implementar alert integrity checks e immutable thresholds	Baixa
T042	Cloud9	E	Privilege escalation através de shared environments	Comprometimento de credenciais de desenvolvimento	Implementar environment isolation e temporary credentials	Alta
T043	Cloud9	I	Code exfiltration através de environment sharing	Vazamento de propriedade intelectual	Configurar VPC private networking e code repository controls	Média
T044	Cloud9	T	Code injection através de	Inserção de código malicioso	Implementar code review	Baixa

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
			collaborative editing		workflows e static analysis	
T045	Application Auto Scaling	D	Resource exhaustion através de scaling policies manipulation	Custos excessivos e degradação	Configurar scaling limits e cost anomaly detection	Média
T046	Application Auto Scaling	E	Privilege escalation através de service-linked roles	Comprometimento de permissões AWS	Review service role permissions e implement boundaries	Baixa
T047	CloudFront	D	Distribution flooding através de cache miss attacks	Sobrecarga da origem	Configurar origin throttling e cache optimization	Média
T048	Application Load Balancer	I	Log exposure através de access logs mal configurados	Vazamento de informações de tráfego	Configurar S3 bucket policies restritivas para logs	Baixa
T049	Compute Instances	D	Resource exhaustion através de fork bomb attacks	Indisponibilidade das instâncias	Implementar ulimits e process monitoring	Baixa
T050	ElastiCache	E	Authentication bypass através de security groups permissivos	Acesso não autorizado ao cache	Configurar security groups restritivos e VPC endpoints	Média
T051	Simple Email Service	D	Rate limiting através de sending quota exhaustion	Bloqueio de emails legítimos	Configurar sending quotas adequadas e	Baixa

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
					reputation monitoring	
T052	Elastic File System	D	Mount target flooding através de excessive connections	Indisponibilidade do file system	Configurar connection limits e mount monitoring	Baixa
T053	AWS Backup	I	Metadata exposure através de backup job details	Revelação de informações de infraestrutura	Configurar IAM permissions granulares para backup jobs	Baixa
T054	AWS Shield	S	False positive através de legitimate traffic classification	Bloqueio de usuários legítimos	Implementar traffic pattern analysis e whitelisting	Baixa
T055	AWS WAF	R	Log tampering através de insufficient retention	Perda de evidências de ataques	Configurar immutable logging e long-term retention	Baixa
T056	Key Management Service	D	Service disruption através de quota exhaustion	Indisponibilidade de operações criptográficas	Monitorar usage quotas e implementar alerting	Baixa
T057	Amazon RDS	S	Connection spoofing através de SSL/TLS misconfiguration	Impersonação de clients legítimos	Forçar SSL connections e validar certificates	Média
T058	CloudTrail	D	Log storage exhaustion através de excessive event generation	Perda de logs por falta de espaço	Configurar S3 lifecycle policies e log archiving	Baixa

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T059	CloudWatch	E	Cross-account access através de resource policies permissivas	Acesso não autorizado a métricas	Implementar least privilege em resource policies	Baixa
T060	Cloud9	D	Environment flooding através de resource consumption	Indisponibilidade do ambiente de desenvolvimento	Configurar resource limits e auto-hibernation	Baixa
T061	Application Auto Scaling	T	Policy manipulation através de inadequate permissions	Alteração não autorizada de scaling behaviors	Implementar policy versioning e change detection	Baixa
T062	CloudFront	E	Edge location privilege abuse através de lambda@edge	Execução de código malicioso na edge	Implementar code review rigoroso para edge functions	Média
T063	Application Load Balancer	S	Target impersonation através de health check manipulation	Redirecionamento para targets maliciosos	Configurar health check authentication e validation	Baixa
T064	Compute Instances	R	Process hiding através de rootkit installation	Ocultação de atividades maliciosas	Implementar host-based intrusion detection e file integrity monitoring	Média
T065	ElastiCache	S	Node impersonation através de cluster misconfiguration	Acesso a dados através de nodes não autorizados	Implementar node authentication	Baixa

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
					e cluster encryption	
T066	Simple Email Service	T	Template injection através de dynamic content	Execução de código através de email rendering	Implementar input validation e template sandboxing	Média
T067	Elastic File System	S	Mount point spoofing através de DNS manipulation	Redirecionamento para file systems maliciosos	Configurar DNS security e mount point validation	Baixa
T068	AWS Backup	D	Recovery time manipulation através de cross-region delays	Aumento do RTO em cenários de disaster recovery	Implementar multi-region backup strategies e RTO monitoring	Baixa

---

3. Resumo por Prioridade

Ameaças Críticas (8)

T001, T007, T011, T019, T020, T028, T031, T036

Ameaças Altas (18)

T002, T004, T005, T008, T012, T014, T018, T021, T023, T025, T029, T032, T033, T037, T039, T042, T061, T062

Ameaças Médias (24)

T003, T006, T009, T013, T015, T017, T022, T026, T027, T034, T038, T040, T043, T045, T047, T050, T057, T062, T064, T066, T003, T006, T009, T013

Ameaças Baixas (18)

T010, T016, T024, T030, T035, T041, T044, T046, T048, T049, T051, T052, T053, T054, T055, T056, T058, T059, T060, T065, T067, T068

---

4. Recomendações Prioritárias

1. **Implementar criptografia end-to-end** - Habilitar encryption at rest/transit em RDS, EFS, ElastiCache e KMS policies restritivas (endereça T011, T019, T028, T031)
2. **Hardening de segurança em instâncias Compute** - Forçar IMDSv2, implementar container scanning e mTLS (endereça T007, T008, T009)
3. **Configurar CloudFront com Origin Access Control** - Implementar signed URLs e certificate monitoring para prevenir exposição de conteúdo (endereça T001, T002)
4. **Implementar backup immutable e cross-account** - Configurar AWS Backup com retention locks e MFA delete (endereça T020, T021)
5. **Configurar logging de auditoria rigoroso** - CloudTrail multi-region com log file integrity validation (endereça T036, T037)

---

5. Próximos Passos

1. **Ação imediata**: Habilitar criptografia em RDS e ElastiCache, configurar IMDSv2 em instâncias EC2
2. **Ação de curto prazo**: Implementar WAF managed rules, configurar CloudFront OAC, e revisar políticas IAM
3. **Ação de médio prazo**: Implementar monitoramento avançado com CloudWatch Insights e estabelecer programa de threat hunting

---

Relatório gerado automaticamente por ferramenta de análise STRIDE.